

Mobile Application Testing Lab Report

Target Application: Damn Vulnerable Bank (dvba.apk)

Tools Used: MobSF, Frida, Drozer

Date: 2025-11-21

EXECUTIVE SUMMARY

The Damn Vulnerable Bank application exhibits **multiple critical security vulnerabilities** that pose significant risks to user data and application integrity. The app scored **5/19** on security metrics, indicating poor security posture. Critical issues include insecure data storage, cleartext communication, and excessive permissions that could lead to data theft and unauthorized access.

DOCKER SETUP & MOBSF DEPLOYMENT

Setup

Launch MobSF container

```
docker run -d --name mobsf -p 8000:8000 opensecurity/mobile-security-framework-mobsf
```

Verify container status

```
docker ps
```

OUTPUT: mobsf container running on port 8000

Access MobSF interface

<http://localhost:8000>

Application Source & Setup

Damn-Vulnerable-Bank:

Clone vulnerable application repository

```
git clone https://github.com/rewanthtammana/Damn-Vulnerable-Bank.git
```

Repository structure examined

```
ls -la Damn-Vulnerable-Bank/
```

Contains: dvba.apk, BackendServer, Source code, Documentation

Target APK file

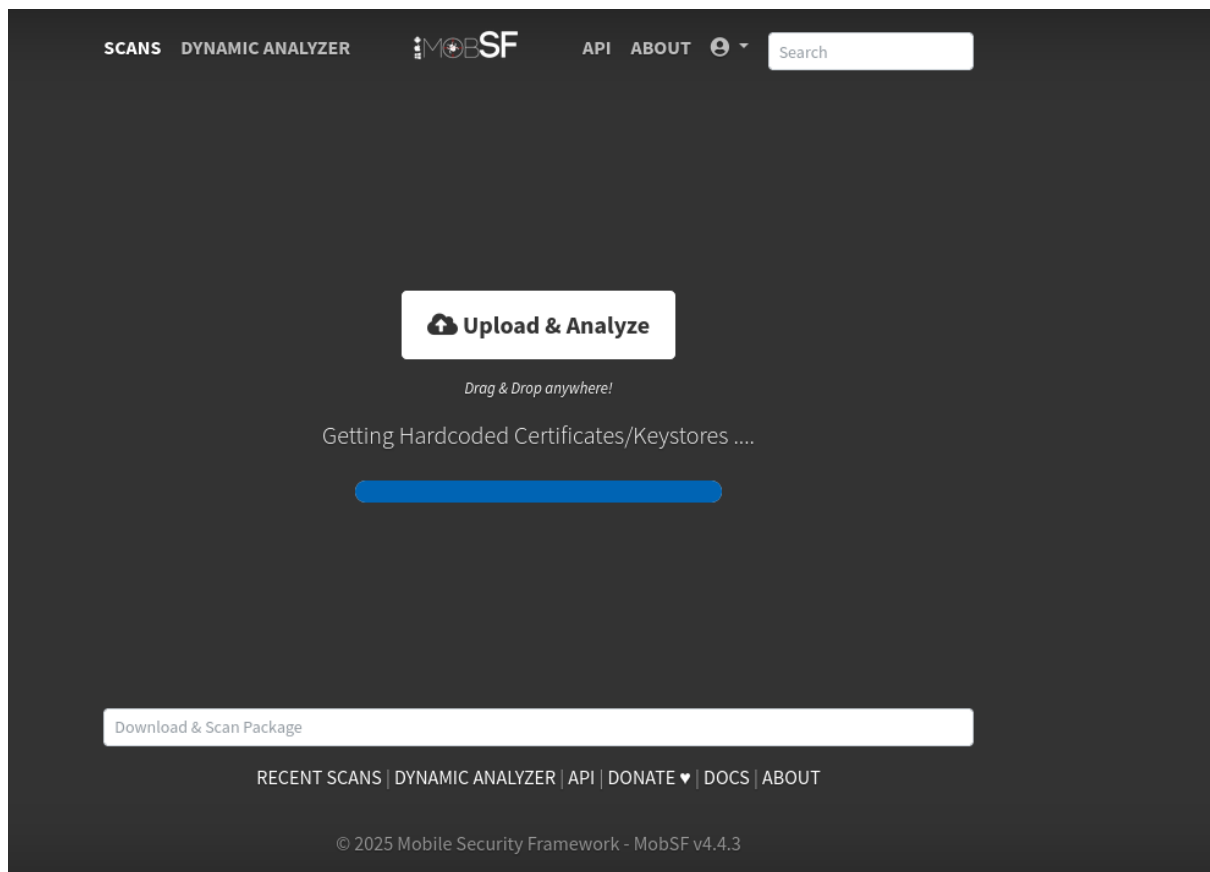
File: dvba.apk (3.78 GB)

Location: ~/Documents/Damn-Vulnerable-Bank/dvba.apk

Static Analysis with MobSF

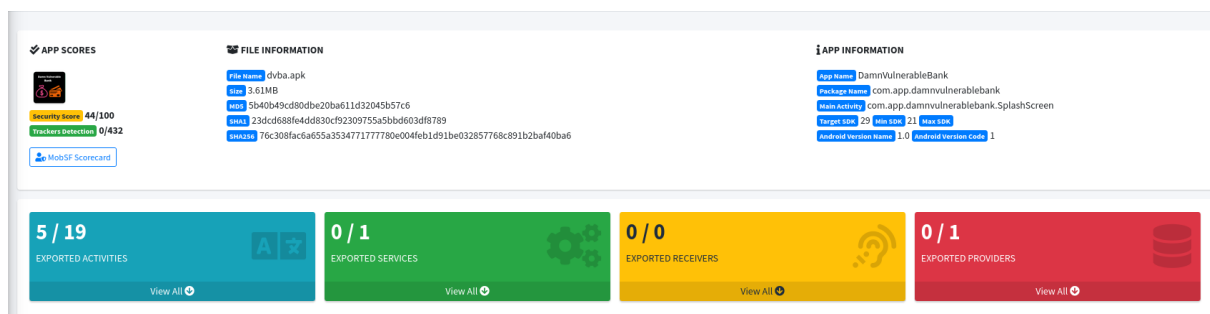
Application Upload & Initial Analysis

Figure 5: MobSF file upload interface with certificate extraction



2.2 Security Score Overview

Figure 6: Application security scoring and basic information



Critical Vulnerabilities Identified:

Test ID	Vulnerability	Severity	Target App	CVSS
001	Insecure Storage (External Storage R/W)	High	dvba.apk	7.5
002	Cleartext Traffic Enabled	High	dvba.apk	7.1
003	Backup Enabled	Medium	dvba.apk	6.5
004	Logging Sensitive Information	Medium	dvba.apk	6.0

3.1 High Severity Issues

Figure 7: Critical and high severity vulnerabilities

NO	ISSUE	SEVERITY	DESCRIPTION	OPTIONS
1	App can be installed on a vulnerable unpatched Android version [android.os.SdkVersionInfo.minSdk<21]	High	This application can be installed on an older version of android that has multiple unfixed vulnerabilities. These devices won't receive reasonable security updates from Google. Support an Android version >= 10, API 29 to receive reasonable security updates.	
2	Clear text traffic is Enabled For App [android:usesCleartextTraffic=true]	High	The app intends to use cleartext network traffic, such as cleartext HTTP, FTP stacks, DownloadManager, and MediaPlayer. The default value for apps that target API level 27 or lower is "true". Apps that target API level 28 or higher default to "false". The key reason for avoiding cleartext traffic is the lack of confidentiality, authenticity, and protections against tampering; a network attacker can eavesdrop on transmitted data and also modify it without being detected.	
3	App has a Network Security Configuration [android:networkSecurityConfig=@xml/network_security_config]	Info	The Network Security Configuration feature lets apps customize their network security settings in a safe, declarative configuration file without modifying app code. These settings can be configured for specific domains and for a specific app.	
4	Application Data can be Backed up [android:allowBackup=true]	Warning	This flag allows anyone to backup your application data via adb. It allows users who have enabled USB debugging to copy application data off of the device.	
5	App Link assetlinks.json file not found [android:name=com.app.damn.vulnerablebank.CurrencyRates] [android:host=http://xe.com]	High	App Link asset verification URL (http://xe.com/.well-known/assetlinks.json) not found or configured incorrectly. (Status Code: 301). App Links allow users to redirect from a web URL/email to the mobile app. If this file is missing or incorrectly configured for the App Link host/domain, a malicious app can hijack such URLs. This may lead to phishing attacks, leak sensitive data in the URI, such as PII, OAuth tokens, magic link/ password reset tokens and more. You must verify the App Link domain by hosting the assetlinks.json file and enabling verification via [android:autoVerify="true"] in the Activity intent-filter.	
6	App Link assetlinks.json file not found [android:name=com.app.damn.vulnerablebank.CurrencyRates] [android:host=https://xe.com]	High	App Link asset verification URL (https://xe.com/.well-known/assetlinks.json) not found or configured incorrectly. (Status Code: 301). App Links allow users to redirect from a web URL/email to the mobile app. If this file is missing or incorrectly configured for the App Link host/domain, a malicious app can hijack such URLs. This may lead to phishing attacks, leak sensitive data in the URI, such as PII, OAuth tokens, magic link/ password reset tokens and more. You must verify the App Link domain by hosting the assetlinks.json file and enabling verification via [android:autoVerify="true"] in the Activity intent-filter.	

Key Issues Identified:

- **Insecure Data Storage:** App can read/write to External Storage (any app can access)
- **Lack of Encryption:** Cleartext HTTP traffic enabled
- **Data Exposure:** Backup allowed via ADB
- **Information Leakage:** Sensitive data logged

Critical Findings:

The application has severe security flaws, primarily Insecure Data Storage (CVSS 7.5) allowing any app to access sensitive data externally, and Cleartext Traffic (CVSS 7.1) enabling unencrypted HTTP communication vulnerable to eavesdropping and MITM attacks.

Medium Severity Issues:

The app permits full data backup via ADB, risks exposing credentials through logging, and targets an outdated Android SDK (API 21) with known unpatched vulnerabilities.

Figure 8: Medium and low severity vulnerabilities

NO	ISSUE	SEVERITY	STANDARDS	FILES	OPTIONS
1	The App logs information. Sensitive information should never be logged.	Info	CWE: CWE-532: Insertion of Sensitive Information into Log File OWASP MASVS: MSTG-STORAGE-3	Show Files	
2	This App may have root detection capabilities.	Secure	OWASP MASVS: MSTG-RESILIENCE-1	a/a/a/a.java	
3	App can read/write to External Storage. Any App can read data written to External Storage.	Warning	CWE: CWE-276: Incorrect Default Permissions OWASP Top 10: M2: Insecure Data Storage OWASP MASVS: MSTG-STORAGE-2	com/app/dammvulnerablebank/MainActivity.java	

Low Severity Notes:

Basic root detection is present but easily bypassed, and missing App Links verification creates potential for URL hijacking.

Standards Violated:

Multiple OWASP MASVS controls (NSTG-STORAGE-2/3), OWASP Mobile Top 10 (M2), and CWE weaknesses (276, 532) are identified.

Overall Risk Assessment:

The application demonstrates critical failures in data protection and network security, making it unsuitable for production use without immediate remediation of storage encryption and communication security issues.